



ACTIVIDAD 01

— Análisis y planificación del Pentest —

MARIA ROSARIO MAMANI POMA

1. Objetivo del Pentest

Con base en el caso de Aurora Market, defino los siguientes tres objetivos concretos para la evaluación de seguridad:

1. Identificar vulnerabilidades de seguridad en la aplicación web de Aurora Market (registro e inicio de sesión, control de acceso entre cuentas, carrito de compras, pagos y consulta de pedidos) que puedan exponer información de los clientes.
2. Determinar si el incidente reportado por un cliente (haber visto información que aparentemente pertenecía a otra cuenta) corresponde a una vulnerabilidad real, identificando su causa —falla de la aplicación, error de permisos o configuración incorrecta— y qué tan grave es.
3. Evaluar qué tan expuesta está la plataforma ante un posible atacante externo, priorizar los riesgos encontrados según su impacto en el negocio y en los clientes, y entregar recomendaciones claras que ayuden a Aurora Market a reducirlos.

2. Alcance

A partir de la autorización y las condiciones que Aurora Market entregó al equipo:

Si se evaluará	Fuera de alcance
• Únicamente la aplicación Web. • Registro de Cuentas, gestión de usuarios. • información de compras, productos, pedidos • Accesos administrativos (personas que pueden administrar y gestionar productos, usuarios, información sensible y pedidos). • Mecanismos y configuración de accesos (cliente, proveedor, empleado).	• No redes sociales oficiales de Aurora Market. • No equipos personales de empleados. • No proveedores externos o sistemas de terceros. • No sistemas que no formen parte del alcance. • No acciones que puedan interrumpir el funcionamiento del servicio.

3. Autorización y condiciones

Permisos requeridos	Condiciones Acordadas
• Autorización formal y escrita de Aurora Market que pueda respaldar la evaluación. • Alcance detallado y firmado de ambas partes donde especifiquen que sistemas incluyen y que no está permitido o incluido • Credenciales o acceso con el mínimo privilegio • Contacto disponible en la evaluación para coordinar la evaluación realizada • Procedimiento y medio de comunicación formal para reportar los hallazgos encontrados	• Evaluar únicamente la aplicación web autorizada; no atacar redes sociales, correos, equipos del personal ni proveedores. • No realizar acciones que interrumpan deliberadamente el funcionamiento de la plataforma ni que afecten información real de los clientes. • Ejecutar las pruebas en horarios de menor actividad, previamente coordinados con Aurora Market. • Mantener confidencialidad, transparencia y comunicación constante con la empresa durante todo el proyecto. • Documentar cuidadosamente cada hallazgo para que el equipo de desarrollo pueda revisarlo y corregirlo después.

4. Tipo de Pentest

Tipo de Pentest elegido: GRAY-BOX (caja gris).

Justificación: Elijo gray-box porque el escenario da información parcial: sabemos que hay app web, base de datos, autenticación y roles, pero no la arquitectura ni tecnologías internas. Gray-box nos permite centrarnos en los riesgos clave y simular un atacante realista.

5. Planificación

Elementos clave que el equipo debe definir antes de comenzar la parte técnica:

5.1. Objetivos

Los tres objetivos definidos en el punto 1: identificar vulnerabilidades, esclarecer el incidente reportado y evaluar la exposición real de la plataforma.

5.2. Alcance

El definido en el punto 2: la aplicación web y el panel administrativo autorizados de Aurora Market, excluyendo redes sociales, correos, equipos del personal y proveedores.

5.3. Permisos y condiciones

Autorización formal firmada, punto de contacto definido, no interrupción del servicio, no afectar datos reales y pruebas en horario de baja actividad

5.4. Metodología a utilizar

OWASP como referencia principal para las pruebas sobre la aplicación web, complementada de forma básica con ISSAF (Information Systems Security Assessment Framework) para dar una estructura general a la evaluación, activos a proteger, alcance, tipos de pruebas y reporte

5.5 Recopilación de información previa

- Revisar la información que Aurora Market ya compartió (existencia de app web, base de datos, autenticación y tipos de usuario) y el reporte del incidente del cliente afectado.
- Recolección pasiva sobre la aplicación autorizada: búsqueda de información pública, análisis del DNS y WHOIS del dominio, y revisión de las tecnologías visibles en el sitio, sin interactuar todavía con el sistema.
- Recolección activa, limitada estrictamente a la aplicación web autorizada: identificación de puertos y servicios expuestos y fingerprinting de tecnologías. No se realizará ingeniería social ni revisión de redes sociales, ya que están fuera del alcance acordado con la empresa.
- Un modelado de amenazas básico (identificar los activos a proteger de la app web, base de datos, cuentas de clientes, las amenazas posibles y su nivel de riesgo) para priorizar en qué enfocar el análisis técnico, conectando la parte técnica con el enfoque de gestión de riesgos.

5.6. Recursos necesarios

- Equipo de pentesting, cuenta(s) de prueba en la plataforma, herramientas de escaneo de puertos y servicios, una herramienta de interceptación y análisis de la aplicación web, y una herramienta de modelado de amenazas (por ejemplo, Microsoft Threat Modeling Tool) para identificar activos y priorizar riesgos.
- Un entorno de trabajo seguro para documentar hallazgos y un canal directo de comunicación con Aurora Market.

5.7. Programación del pentest

Cronograma acordado con la empresa, ejecutando las pruebas en horarios de menor actividad (por ejemplo, madrugadas o fines de semana) y organizado por fases (reconocimiento, análisis, explotación, post-explotación e informe) con fechas definidas para cada una.

6. Fases

Cómo aplicaría cada fase al caso concreto de Aurora Market:

6.1. Reconocimiento

Recopilar toda la información disponible sobre la aplicación autorizada de Aurora Market: funcionalidades visibles para clientes y para el personal administrativo, tipos de cuenta, flujo de registro/login y cualquier tecnología detectable, apoyándome en lo poco que la empresa ya compartió (existe app web, base de datos, autenticación y varios tipos de usuario), sin explotar nada todavía.

6.2. Análisis de vulnerabilidades

Buscar debilidades concretas en el inicio de sesión, la gestión de sesiones, el control de acceso entre cuentas (clave para entender el incidente reportado), la validación de datos en formularios, y el proceso de carrito y pago, combinando herramientas de escaneo con revisión manual.

6.3. Explotación

Comprobar de forma controlada, sin dañar información real de clientes, si las vulnerabilidades encontradas realmente pueden aprovecharse; en particular, intentar reproducir de forma segura el escenario reportado por el cliente (ver datos de otra cuenta) para confirmar si corresponde a una falla real.

6.4. Post-explotación

Evaluar qué información o accesos podría obtener un atacante real a partir de cada vulnerabilidad confirmada —por ejemplo, si podría ver datos de otros clientes, modificar pedidos o llegar al panel administrativo— y qué tan grave sería ese impacto para el negocio y la confianza de sus clientes.

6.5. Informe

Documentar cada hallazgo de forma clara y ordenada (qué se encontró, cómo se comprobó y qué riesgo representa), indicar si el incidente reportado por el usuario corresponde a una vulnerabilidad real, y entregar recomendaciones priorizadas para que el equipo de desarrollo de Aurora Market pueda corregir los problemas.

6. Investigación

METODOLOGÍA ELEGIDA

OWASP

- Concientización y educación
- Documentación de riesgos
- Herramientas y recursos
- Comunidad colaborativa

ISSAF (Information Systems Security Assessment Framework)

- Enfoque basado en activos
- Consideraciones éticas y legales
- Tipos de pruebas
- Procesos y actividades de pruebas
- Herramientas y técnicas
- Reporte de resultados

¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?

OWASP es la referencia más usada para aplicaciones web como la de Aurora Market. Sirve para educar al equipo sobre los riesgos, te da documentación y herramientas para saber qué y cómo revisar (por ejemplo, el Top 10, donde “fallas de control de acceso” coincide con el incidente del cliente), y se mantiene actualizada gracias a su comunidad.

ISSAF complementa con una visión más de proyecto: te ayuda a identificar qué proteger (app, BD, datos de clientes), respalda los aspectos éticos y legales, ordena las fases de

prueba, sugiere herramientas y técnicas para cada una, y asegura que los resultados se reporten de forma clara.

Usar ambas cubre lo técnico (OWASP) y el marco general del proyecto (ISSAF).